

Report Tecnico di Sicurezza

Implementazione e Verifica della Gestione dei Gruppi Utente — Windows Server 2022

Campo	Dettaglio
Autore	Leonardo Onori
Corso	Cybersecurity and Ethical Hacking (Epicode)
Data	28 Agosto 2026
Ambiente target	Windows Server 2022 — Domain Controller, dominio Epicode.local
Classificazione	Uso didattico / Interno

1. Executive Summary

Il presente report documenta l'attività di hardening organizzativo condotta su un Domain Controller Windows Server 2022, tramite la creazione di gruppi di sicurezza dedicati e l'assegnazione di permessi differenziati secondo il principio del minimo privilegio (*Principle of Least Privilege*, PoLP). Sono stati creati due gruppi — **G_MarketingTeam** e **G_Sviluppatori** — a cui sono stati associati permessi distinti su risorse file, esecuzione applicativa, impostazioni di sistema e accesso remoto. La configurazione è stata validata tramite utenti di prova e verifica delle Access Control List (ACL) effettive. Tutti i controlli pianificati sono risultati conformi alle aspettative, confermando l'efficacia della segregazione dei privilegi implementata.

2. Scope (Ambito)

In scope:

- Creazione di due gruppi di sicurezza in Active Directory
- Assegnazione permessi su: file/cartelle condivise, esecuzione programmi, impostazioni di sistema, accesso remoto (RDP)
- Creazione e test di utenti dimostrativi
- Verifica documentale delle ACL tramite strumenti nativi (icacls, cmdlet AD)

Out of scope:

- Hardening completo del Domain Controller (patching, GPO di sicurezza avanzate, auditing)
- Configurazione di Fine-Grained Password Policy
- Test di penetrazione o simulazione di attacco reale contro i controlli implementati

3. Methodology (Metodologia)

L'attività è stata condotta interamente tramite console amministrativa PowerShell sul Domain Controller, seguendo un approccio incrementale a step verificabili:

1. **Ricognizione ambiente** — identificazione del contesto (DC in dominio Epicode.local) tramite `whoami` e `systeminfo`
2. **Provisioning** — creazione dei gruppi tramite modulo ActiveDirectory (`New-ADGroup`)
3. **Hardening dei permessi** — applicazione di ACL NTFS granulari (`icacls`) con rimozione dell'ereditarietà di default, assegnazione a gruppi AD tramite `Add-ADGroupMember`
4. **Validazione** — creazione di utenti di test, assegnazione ai gruppi, e verifica dei permessi effettivi tramite un client Windows 10 joinato al dominio, autenticato con gli account di test e operante su risorse condivise reali (SMB e RDP)

La scelta di validare da un client esterno anziché dalla console del Domain Controller è motivata da un vincolo intrinseco di sicurezza di Windows Server: su un DC, per policy predefinita, solo gli account con diritto esplicito di *logon locale* possono autenticarsi sulla console, indipendentemente dai permessi NTFS o dall'appartenenza ad altri gruppi. Testare da un client di dominio replica quindi le condizioni operative reali di un utente aziendale, offrendo una validazione più rappresentativa rispetto alla sola analisi documentale delle ACL.

```
PS C:\Users\Administrator> whoami /groups | findstr "Administrators"
>> systeminfo | findstr /B /C:"Domain"
BUILTIN\Administrators Alias S-1-5-32-544 Mandatory group, Enabled by default, Enabled group, Group owner
Domain: Epicode.local
PS C:\Users\Administrator>
```

3.1 Ambiente di test

Componente	Dettaglio
Domain Controller	EpicodeServer, IP 192.168.50.10, dominio Epicode.local
Client di validazione	Windows 10, IP 192.168.50.20, joinato al dominio Epicode.local
Rete	Rete interna (VirtualBox), rete "intnet"
Condivisioni SMB create	\\192.168.50.10\Marketing, \\192.168.50.10\Sviluppo, \192.168.50.10\ToolSviluppo

Le cartelle C:\Condivise\Marketing, C:\Condivise\Sviluppo e C:\Program Files\ToolSviluppo, già protette da ACL NTFS granulari (cfr. sez. 4.2), sono state condivise in rete tramite New-SmbShare per renderle raggiungibili dal client di test, mantenendo inalterate le restrizioni NTFS sottostanti come livello di sicurezza primario.

```
PS C:\Users\Administrator> New-SmbShare -Name "ToolSviluppo" -Path "C:\Program Files\ToolSviluppo" -ReadAccess "Epicode\G_MarketingTeam","Epicode\G_Sviluppatori"
Name      ScopeName Path Description
----
ToolSviluppo * C:\Program Files\ToolSviluppo

PS C:\Users\Administrator> Get-SmbShare | Select Name, Path
Name      Path
----
ADMIN$    C:\Windows
C$        C:\
Dati Segreti C:\Dati Sensibili\Dati Segreti
Dati Top   C:\Dati Sensibili\Dati Top
IPC$      C:\Windows\WinSxS
Marketing  C:\Condivise\Marketing
NETLOGON  C:\Windows\SYSTEM32\sysvol\Epicode.local\SCRIPTS
Sviluppo   C:\Condivise\Sviluppo
SYSVOL     C:\Windows\SYSTEM32\sysvol
ToolSviluppo C:\Program Files\ToolSviluppo

PS C:\Users\Administrator> Get-ADComputer -Filter * | Select-Object Name, DNSHostName
Name      DNSHostName
----
EPICODESERVER EpicodeServer.Epicode.local
DESKTOP-8CAJRT0 DESKTOP-8CAJRT0.Epicode.local
ADMIN$
C$
Dati Segreti
Dati Top
IPC$
Marketing
NETLOGON
Sviluppo
SYSVOL
ToolSviluppo

PS C:\Users\Administrator>
```

4. Findings (Risultati)

4.1 Asset creati

ID	Gruppo	Categoria	Scope	Funzione
G-01	G_MarketingTeam	Security	Global	Reparto Marketing
G-02	G_Sviluppatori	Security	Global	Team Sviluppo

```
PS C:\Users\Administrator> Get-ADGroup -Filter 'Name -like "G_*"' | Select-Object Name, GroupCategory, GroupScope
Name                GroupCategory GroupScope
-----
G_MarketingTeam      Security      Global
G_Sviluppatori       Security      Global

PS C:\Users\Administrator> _
```

4.2 Matrice dei permessi assegnati

Risorsa	G_MarketingTeam	G_Sviluppatori	Motivazione tecnica
C:\Condivise\Marketing	Modify (concesso)	Nessun accesso	Accesso esclusivo al reparto proprietario del dato
C:\Condivise\Sviluppo	Nessun accesso	Modify (concesso)	Isolamento dei repository di sviluppo da altri reparti
C:\Program Files\ToolSviluppo	Deny esplicito (RX)	Read & Execute (concesso)	Deny esplicito per rendere la restrizione inequivocabile e prioritaria su eventuali permessi ereditati futuri
Impostazioni di sistema	Nessun privilegio	Nessun privilegio	Nessuno dei due gruppi è membro di Domain Admins/Administrators
Accesso remoto (RDP)	Negato	Consentito (membro di Remote Desktop Users)	Necessità operativa di accesso remoto limitata al team Sviluppo

```

PS C:\Users\Administrator> icacls "C:\Condivise\Marketing"
>> icacls "C:\Condivise\Sviluppo"
C:\Condivise\Marketing EPICODE\Domain Admins:(OI)(CI)(F)
                        EPICODE\G_MarketingTeam:(OI)(CI)(M)

Successfully processed 1 files; Failed processing 0 files
C:\Condivise\Sviluppo EPICODE\Domain Admins:(OI)(CI)(F)
                      EPICODE\G_Sviluppatori:(OI)(CI)(M)

Successfully processed 1 files; Failed processing 0 files
PS C:\Users\Administrator> S

```

```

PS C:\Users\Administrator> icacls "C:\Program Files\ToolSviluppo"
C:\Program Files\ToolSviluppo EPICODE\G_MarketingTeam:(OI)(CI)(DENY)(RX)
                              EPICODE\Domain Admins:(OI)(CI)(F)
                              EPICODE\G_Sviluppatori:(OI)(CI)(RX)

Successfully processed 1 files; Failed processing 0 files
PS C:\Users\Administrator> _

```

```

PS C:\Users\Administrator> Get-ADGroupMember -Identity "Remote Desktop Users" | Select-Object Name
>> Get-ADGroupMember -Identity "Domain Admins" | Select-Object Name

Name
----
G_Sviluppatori
Administrator

PS C:\Users\Administrator>

```

Nota tecnica rilevante: su un Domain Controller i gruppi built-in come *Remote Desktop Users* non risiedono nel database SAM locale ma nel container *Builtin* di Active Directory; è stato pertanto necessario utilizzare *Add-ADGroupMember* in luogo di *Add-LocalGroupMember* (che avrebbe restituito errore *GroupNotFoundException*).

4.3 Validazione tramite client Windows 10 di dominio

Utente	Gruppo	Scopo
TestMarketing	G_MarketingTeam	Validazione permessi reparto Marketing
TestSviluppo	G_Sviluppatori	Validazione permessi reparto Sviluppo

```

PS C:\Users\Administrator> Get-ADGroupMember -Identity "G_MarketingTeam" | Select-Object Name
>> Get-ADGroupMember -Identity "G_Sviluppatori" | Select-Object Name

Name
----
Test Marketing
Test Sviluppo

PS C:\Users\Administrator> _

```

La validazione è stata condotta da un client Windows 10 (192.168.50.20) unito al dominio Epicode.local, autenticandosi in sequenza con entrambi gli account di test ed eseguendo operazioni reali di accesso a risorse condivise (mount SMB, lettura contenuti, connessione RDP).

Controllo	Esito atteso	Esito osservato	Stato
TestMarketing → accesso a Marketing (net use + dir)	Consentito	Consentito	Conforme
TestMarketing → accesso a Sviluppo (net use + dir)	Negato	Accesso negato	Conforme
TestMarketing → lettura ToolSviluppo (dir \\...\ToolSviluppo)	Negato (deny)	Accesso negato	Conforme
TestMarketing → RDP (mstsc)	Negato	Connessione rifiutata, utente non autorizzato	Conforme
TestSviluppo → accesso a Sviluppo (net use + dir)	Consentito	Consentito	Conforme
TestSviluppo → accesso a Marketing (net use + dir)	Negato	Accesso negato	Conforme
TestSviluppo → lettura ToolSviluppo (dir \\...\ToolSviluppo)	Consentito	Consentito	Conforme
TestSviluppo → RDP (mstsc)	Consentito	Connessione riuscita	Conforme
Entrambi i gruppi → privilegi amministrativi	Assenti	Assenti (nessuna membership in Domain Admins)	Conforme

Tutti i controlli pianificati hanno prodotto un esito conforme alle aspettative, confermando che la segregazione dei privilegi implementata tramite gruppi di sicurezza e ACL NTFS si traduce correttamente in un comportamento di accesso reale e verificabile lato client, coerente con il modello Least Privilege adottato.

```

PS C:\Users\TestSviluppo> net use Z: \\192.168.50.10\Marketing
Errore di sistema 85.

Nome di dispositivo locale già in uso.

PS C:\Users\TestSviluppo> net use Y: \\192.168.50.10\Sviluppo
Errore di sistema 85.

Nome di dispositivo locale già in uso.

PS C:\Users\TestSviluppo> dir Z:
dir : Accesso negato
In riga:1 car:1
+ dir Z:
+ ~~~~~
+ CategoryInfo          : PermissionDenied: (Z:\:String) [Get-ChildItem], UnauthorizedAccessException
+ FullyQualifiedErrorId : ItemExistsUnauthorizedAccessError,Microsoft.PowerShell.Commands.GetChildItemCommand

dir : Impossibile trovare il percorso 'Z:\' perché non esiste.
In riga:1 car:1
+ dir Z:
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (Z:\:String) [Get-ChildItem], ItemNotFoundException
+ FullyQualifiedErrorId : PathNotFound,Microsoft.PowerShell.Commands.GetChildItemCommand

PS C:\Users\TestSviluppo> dir Y:
PS C:\Users\TestSviluppo> dir \\192.168.50.10\ToolSviluppo
PS C:\Users\TestSviluppo>

```

```

PS C:\Users\TestMarketing> dir Z:
PS C:\Users\TestMarketing> net use Z: \\192.168.50.10\Marketing
>> net use Y: \\192.168.50.10\Sviluppo
>> dir Z:
>> dir Y:
>> dir \\192.168.50.10\ToolSviluppo
Errore di sistema 85.

Nome di dispositivo locale già in uso.

Errore di sistema 85.

Nome di dispositivo locale già in uso.

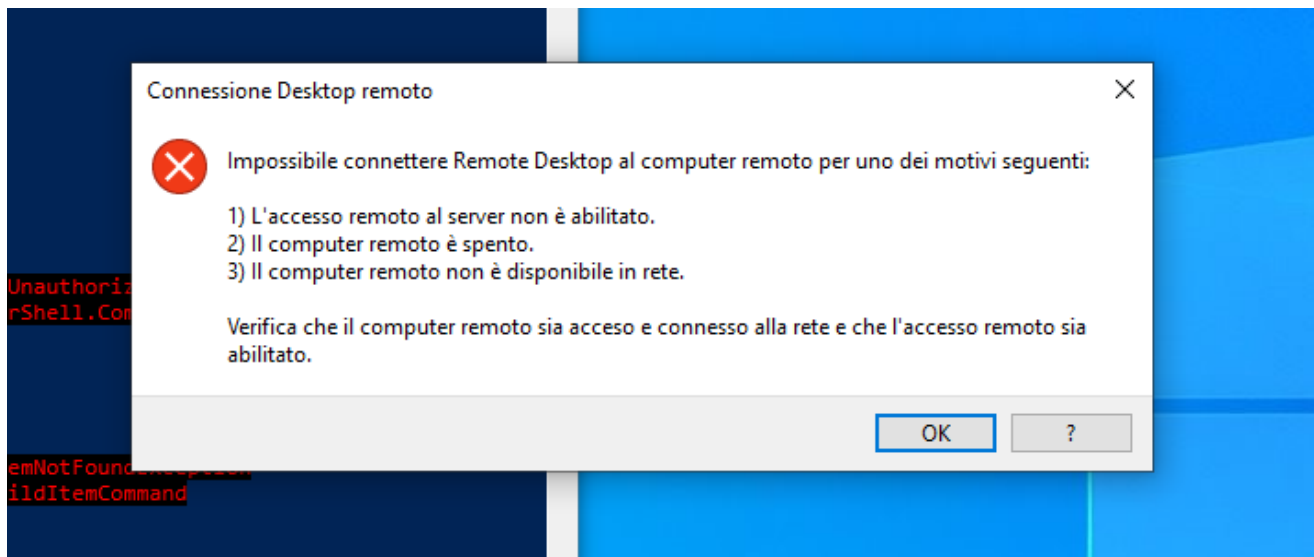
dir : Accesso negato
In riga:4 car:1
+ dir Y:
+ ~~~~~
+ CategoryInfo          : PermissionDenied: (Y:\:String) [Get-ChildItem], UnauthorizedAccessException
+ FullyQualifiedErrorId : ItemExistsUnauthorizedAccessError,Microsoft.PowerShell.Commands.GetChildItemCommand

dir : Impossibile trovare il percorso 'Y:\' perché non esiste.
In riga:4 car:1
+ dir Y:
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (Y:\:String) [Get-ChildItem], ItemNotFoundException
+ FullyQualifiedErrorId : PathNotFound,Microsoft.PowerShell.Commands.GetChildItemCommand

dir : Accesso al percorso '\\192.168.50.10\ToolSviluppo' negato.
In riga:5 car:1
+ dir \\192.168.50.10\ToolSviluppo
+ ~~~~~
+ CategoryInfo          : PermissionDenied: (\\192.168.50.10\ToolSviluppo:String) [Get-ChildItem], UnauthorizedAccess
+ FullyQualifiedErrorId : DirUnauthorizedAccessError,Microsoft.PowerShell.Commands.GetChildItemCommand

PS C:\Users\TestMarketing>

```



5. Risk Assessment (Valutazione del rischio)

Rischio potenziale (in assenza dei controlli)	Impatto	Probabilità	Mitigazione implementata
Accesso incrociato tra reparti a dati sensibili	Alto	Media	Segregazione NTFS con rimozione ereditarietà
Esecuzione non autorizzata di tool di sviluppo da account non tecnici	Medio	Media	Deny esplicito su ToolSviluppo
Escalation di privilegi tramite gruppi operativi	Alto	Bassa	Nessuna membership in gruppi amministrativi
Accesso remoto non controllato al server	Alto	Media	RDP limitato al solo gruppo Sviluppatori

La configurazione implementata riduce significativamente la superficie di attacco interna, in linea con il modello Zero Trust / Least Privilege.

6. Recommendations (Raccomandazioni)

Per un ambiente di produzione, si raccomanda di estendere quanto realizzato in questo esercizio con:

- Applicazione di **Group Policy Object (GPO)** dedicate per il controllo del logon locale/RDP per OU
- Abilitazione di **audit logging** (Security Event Log) sugli accessi alle cartelle condivise sensibili
- Revisione periodica della membership dei gruppi (*access recertification*)
- Adozione di gruppi AGDLP (Account → Global → Domain Local → Permission) per ambienti multi-dominio più complessi

7. Conclusion (Conclusioni)

L'esercizio ha permesso di implementare correttamente una segregazione dei privilegi basata su gruppi in un ambiente Active Directory, verificando ogni singolo controllo pianificato attraverso strumenti nativi di Windows Server. Tutti i test di conformità hanno dato esito positivo, confermando che l'architettura dei permessi rispetta il principio del minimo privilegio e fornisce una base solida di sicurezza organizzativa, ulteriormente rafforzata dalle restrizioni intrinseche di sicurezza di un Domain Controller.

